

Healthcare Security MVP: 3-Session Team Plan

This document describes a 3-session (2 hours each), 4-member plan to implement a minimal viable product (MVP) for a healthcare security middleware prototype. It uses the CERT insider threat dataset as a proxy for EHR system logs (because real EHR logs are protected by HIPAA). We will detect suspicious behaviors, map them to CAPEC/ATT&CK; attack patterns, build a graph, and add a small DICOM CVE slice. The outputs will be images (PNG), events CSV, and a graph file (GraphML).

Why and What (Step-by-Step Logic)

- **Rules (Behavior Fingerprints):** We define simple rules based on abnormal patterns in logon/file events (e.g., many logins at night, writing to USB). These map activity to CAPEC/ATT&CK; attack patterns. This gives us "behavioral fingerprints" from raw logs.
- **Event CSV:** Each detection is stored in an events table with user, timestamp, evidence, and mapped CAPEC/ATT&CK; IDs. This provides a structured record of suspicious events.
- **Graph:** We build a graph where nodes are Users, Activities, Resources, CAPEC/ATT&CK; patterns, and edges connect them (e.g., User→Activity→CAPEC). The graph integrates rules + detections and shows relationships visually.
- **DICOM CVE Slice:** We manually add 1–2 real CVEs (from DICOM software) mapped to CWE→CAPEC. This shows how vulnerability data can join the behavior graph. This way, the system unifies behavior-based and vulnerability-based fingerprints.

Session 1 (2 hrs)

- Set up environment (Python, pandas, networkx, matplotlib, pyyaml).
- Teammate A: Clean CERT dataset (logon.csv, file.csv) into usable form.
- Teammate B: Implement simple rule detectors (off-hours logons, USB writes, multi-PC bursts). Save results into events.csv.
- Teammate C: Build a graph (User→Activity→CAPEC/ATT&CK;) from events.csv. Save graph.graphml and graph_overview.png.
- Teammate D: Prepare config.yml for thresholds + initial docs/README.

Session 2 (2 hrs)

- Teammate A: Make rules use config.yml for easy tuning.
- Teammate B: Generate per-user subgraph PNGs from the graph.
- Teammate C: Add a tiny DICOM CVE slice (CVE→CWE→CAPEC) into the graph.
- Teammate D: Write short docs (rules.md, demo-script.md).

Session 3 (2 hrs)

- Teammate A: Write run_mvp.sh (or .bat) to run all steps automatically.
- Teammate B: Improve graph visuals (CAPEC/ATT&CK; nodes bigger).
- Teammate C: Quality-check events.csv and graph outputs.
- Teammate D: Finalize README (explain CERT as proxy for EHR, limitations, next steps), zip outputs.

Final Deliverables:

- /out/events.csv (suspicious events table)
- /out/graph.graphml (graph database file)
- /out/graph_overview.png (visual of whole graph)

- /out/graph_user_.png (per-user subgraphs)
- /out/graph_cve_slice.png (DICOM CVE slice)
- /docs/rules.md, /docs/demo-script.md, README.md
- run_mvp.sh or run_mvp.bat script

Limitations & Next Steps:

- CERT dataset is not healthcare-specific but log fields (login, file access) are analogous to hospital EHR usage.
- Rules are handcrafted (simple heuristics). In future, frequent subgraph mining or ML models can learn fingerprints automatically.
- Current graph size is ~10k–100k edges (from dataset slice). Enough to explore subgraph matching later.
- In future phases, real EHR CVEs (from NVD/DICOM/FHIR products) can be bulk added to extend the vulnerability slice.